

รายงานโครงงานเครือข่ายคอมพิวเตอร์

การติดตั้งเว็บเซิร์ฟเวอร์และระบบรักษาความปลอดภัยบนคลาวด์

ด้วย Microsoft Azure, Ubuntu, Nginx และ WordPress

รายวิชา 88633065-65

Computer Networks เครือข่ายคอมพิวเตอร์

โดย

นายศิวกร พวงเงินดี รหัส 67160056

นายกฤตภาส มีบุญล้ำ รหัส 67160058

นายณัฐชนน แสงแก้ว รหัส 67160090

นายธรรมวุติ แสนสา รหัส 67160095

นายปฐวี ฤทธิ์ประเสริฐ รหัส 67160097

นางสาวศศิมล โสภากุล รหัส 67160106

นายกรพบ บุญล้อม รหัส 67160246

เสนอ ผศ.ภูสิต กุลเกษม

คณะ วิทยาการสารสนเทศ

มหาวิทยาลัยบูรพา

ภาคเรียนที่ 1 ปีการศึกษา 2569

คำนำ

รายงานฉบับนี้จัดทำขึ้นเพื่ออธิบายการออกแบบ ติดตั้ง
และทดสอบระบบเครือข่ายสำหรับให้บริการเว็บไซต์บนเครื่องเสมือนในระบบคลาวด์ โดยใช้ Microsoft Azure เป็นผู้ให้บริการโครงสร้างพื้นฐาน ติดตั้ง Ubuntu Server, Nginx, PHP, MySQL และ WordPress พร้อมเพิ่มมาตรการรักษาความปลอดภัยตั้งแต่การเข้าถึงเครื่อง การกรองทราฟฟิกเครือข่าย ไปจนถึงการตรวจสอบบันทึกการใช้งานและสรุปเหตุการณ์ด้วย AI โครงงานนี้เป็นการประยุกต์แนวคิดแบบจำลอง OSI 7 Layers และ TCP/IP Model ในสถานการณ์จริงบนระบบคลาวด์
โดยเชื่อมโยงการสื่อสารระดับเครือข่ายกับการให้บริการเว็บและการรักษาความปลอดภัยหลายชั้น

เนื้อหาประกอบด้วยพื้นฐานเครือข่ายและเทคโนโลยีที่เกี่ยวข้อง เหตุผลในการเลือกใช้เครื่องมือ ขั้นตอนการดำเนินงาน ผลการทดสอบจากข้อมูลที่บันทึกไว้ ปัญหาที่พบ และข้อเสนอแนะสำหรับการดูแลระบบต่อไป ทั้งนี้ ตัวเลขผลการดำเนินงานอ้างอิงจากเอกสารขั้นตอน บันทึกสถิติ และภาพหน้าจอของระบบ ณ วันที่ 28–29 ตุลาคม 2569

ผู้จัดทำขอขอบคุณอาจารย์ผู้สอนและแหล่งข้อมูลทางเทคนิคที่ช่วยให้สามารถศึกษาและดำเนินโครงงานนี้ได้

สารบัญ

คำนำ 2
บทที่ 1 บทนำ 4
1.1 ที่มาและความสำคัญ 4
1.2 วัตถุประสงค์ 4
1.3 ขอบเขตของโครงงาน 4
1.4 ประโยชน์ที่คาดว่าจะได้รับ 5
บทที่ 2 ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง 6
2.1 พื้นฐานเครือข่ายและการสื่อสาร 6
2.2 คลาวด์และเครื่องเสมือน 6
2.3 DNS และ HTTPS 6
2.4 Firewall และการกรอง IP 6
2.5 เว็บเซิร์ฟเวอร์และ Reverse Proxy 7
2.6 การตรวจจับการโจมตีและ AI SecOps 7
บทที่ 3 วิธีดำเนินงาน 8
3.1 ภาพรวมสถาปัตยกรรม 8
3.2 การเตรียมเครื่องเซิร์ฟเวอร์ 10
3.3 การติดตั้งเว็บและ HTTPS 10
3.4 การตั้งค่าความปลอดภัยเครือข่าย 11
3.5 การติดตั้ง Dashboard และ AI 11
บทที่ 4 ผลการดำเนินงานและการทดสอบ 13
4.1 ผลการทำงานของระบบ 13
4.2 ผลสถิติจาก Access Log 14
4.3 ผลการทดสอบ 15
4.4 ข้อจำกัดในการแปลผล 16
บทที่ 5 สรุปผล ปัญหา และข้อเสนอแนะ 18
5.1 สรุปผล 18
5.2 ปัญหาที่พบและแนวทางแก้ไข 18
5.3 ข้อเสนอแนะ 19
บรรณานุกรม / เอกสารอ้างอิง 20
ภาคผนวก ก ภาพหน้าจอระบบ 21
ภาคผนวก ข หลักฐานผลการทดสอบคำสั่งและการรักษาความปลอดภัย 23

บทที่ 1 บทนำ

1.1 ที่มาและความสำคัญ

เว็บไซต์ที่เปิดให้เข้าถึงผ่านอินเทอร์เน็ตต้องอาศัยทั้งระบบเครือข่าย เว็บเซิร์ฟเวอร์ ฐานข้อมูล และมาตรการรักษาความปลอดภัย หากเปิดบริการโดยไม่จำกัดการเข้าถึง อาจพบคำขออัตโนมัติจากบอต การสแกนหาช่องโหว่ การเดารหัสผ่าน และการเรียกใช้ส่วนประกอบของ WordPress ที่ไม่จำเป็น การป้องกันด้วยไฟร์วอลล์เพียงอย่างเดียวไม่สามารถจัดการคำขอที่ผ่านเข้ามาถึงชั้นเว็บหรือช่องโหว่ระดับแอปพลิเคชันได้ทั้งหมด ขณะเดียวกันการป้องกันเฉพาะในเว็บแอปพลิเคชันก็ไม่สามารถทดแทนการควบคุมการเข้าถึงเครือข่ายได้ จึงควรใช้แนวคิด Defense-in-Depth หรือการป้องกันแบบหลายชั้น
เพื่อให้แต่ละชั้นช่วยลดความเสี่ยงและชดเชยข้อจำกัดของชั้นอื่น

โครงงานนี้จึงนำเว็บ WordPress ไปติดตั้งบนเครื่องเสมือน Ubuntu ใน Microsoft Azure และวางมาตรการป้องกันหลายชั้น ได้แก่ การใช้ SSH key แทนรหัสผ่าน การเข้ารหัส HTTPS การจำกัดทราฟฟิกด้วย iptables และ ipset การป้องกันการเรียก XML-RPC การจำกัดอัตราคำขอหน้าเข้าสู่ระบบ การใช้ fail2ban และการวิเคราะห์บันทึกการใช้งานผ่านแดชบอร์ด SecDash โดยแต่ละชั้นมีหน้าที่ต่างกัน
ตั้งแต่การกรองการเชื่อมต่อที่ระดับเครือข่าย ไปจนถึงการตรวจสอบคำขอ HTTP และการเฝ้าระวังเหตุการณ์

1.2 วัตถุประสงค์

- เพื่อสร้างเว็บเซิร์ฟเวอร์ที่เข้าถึงได้ผ่านชื่อโดเมนและ HTTPS
- เพื่อประยุกต์ใช้แนวคิดเครือข่ายและการกรองแพ็กเก็ตในการจำกัดการเข้าถึงบริการ
- เพื่อเพิ่มความปลอดภัยให้ SSH, WordPress, Nginx และฐานข้อมูล
- เพื่อรวบรวมและแสดงสถิติจาก HTTP access log และใช้ AI ช่วยสรุปแนวโน้มภัยคุกคาม
- เพื่อทดสอบการทำงานและบันทึกผลอย่างเป็นระบบ

1.3 ขอบเขตของโครงงาน

ระบบประกอบด้วย VM บน Azure, Ubuntu Server 24.04.5 LTS, Nginx 1.24.0, PHP-FPM 8.3, MySQL 8.0, WordPress 6.8, DuckDNS, ใบรับรอง Let's Encrypt, iptables/ipset, fail2ban และ SecDash ที่พัฒนาด้วย Vue 3, TypeScript, Vite และ Tailwind CSS

ทั้งนี้ ระบบได้มีมาตรการป้องกัน Admin Self-Ban และบันทึกประวัติการแก้ไขกฎลง Audit Logs
เพื่อความปลอดภัยในการบริหารจัดการ

1.4 ประโยชน์ที่คาดว่าจะได้รับ

ผู้จัดทำได้ฝึกตั้งค่าเครือข่ายและบริการเว็บบนคลาวด์ เข้าใจการทำงานร่วมกันของ DNS, TCP/IP, firewall, reverse proxy และฐานข้อมูล ตลอดจนเรียนรู้ว่าการอ่าน log
และการทดสอบจากหลักฐานมีความสำคัญต่อการประเมินความปลอดภัยอย่างไร

บทที่ 2 ทฤษฎีและเทคโนโลยีที่เกี่ยวข้อง

2.1 พื้นฐานเครือข่ายและการสื่อสาร

การสื่อสารผ่านเครือข่ายอาศัยหมายเลข IP เพื่อระบุปลายทาง และใช้พอร์ตเพื่อแยกบริการบนเครื่องเดียวกัน ตัวอย่างเช่น SSH ใช้พอร์ต 22, HTTP ใช้พอร์ต 80 และ HTTPS ใช้พอร์ต 443 ส่วน subnet mask หรือ CIDR ใช้ระบุส่วนเครือข่ายและส่วนโฮสต์ของ IP การกำหนดกฎ firewall จึงต้องพิจารณาทั้งต้นทาง โปรโตคอล และพอร์ตปลายทาง

เอกสารประกอบการเรียนเครือข่ายที่ค้นพบอธิบายตัวอย่าง IPv4, network address, broadcast address และการแบ่ง subnet เช่น 192.168.1.1/24 ซึ่งมี network address เป็น 192.168.1.0 และ broadcast address เป็น 192.168.1.255 เนื้อหานี้เชื่อมโยงกับโครงงานในส่วนการทำความเข้าใจช่วง IP และการจัดกลุ่มเครือข่ายสำหรับกฎกรองทราฟฟิก

2.2 คลาวด์และเครื่องเสมือน

Microsoft Azure ให้บริการเครื่องเสมือน (Virtual Machine: VM)
ซึ่งทำหน้าที่เสมือนเซิร์ฟเวอร์ที่เชื่อมต่อเครือข่ายได้ โดยโครงงานใช้ Azure for Students และเลือกภูมิภาค Indonesia Central ตามข้อจำกัดของบัญชีนักศึกษา ขนาดเครื่องที่ระบุคือ Standard_B2als_v2 จำนวน 2 vCPU และ RAM 4 GB

2.3 DNS และ HTTPS

DuckDNS ทำหน้าที่เชื่อมชื่อโดเมน nenenainaemak.duckdns.org เข้ากับ Public IP ของ VM ส่วน HTTPS ใช้ TLS เข้ารหัสการรับส่งข้อมูลระหว่างผู้ใช้กับเว็บเซิร์ฟเวอร์ โครงงานใช้ใบรับรอง Let's Encrypt ผ่าน DNS-01 Challenge ซึ่งตรวจสอบสิทธิ์ในโดเมนผ่านระเบียน DNS แทนการให้ผู้ตรวจสอบเชื่อมต่อพอร์ต 80 จากทั่วโลก

2.4 Firewall และการกรอง IP

iptables เป็นเครื่องมือกำหนดกฎกรองแพ็กเก็ตใน Linux ส่วน ipset ใช้เก็บชุดเครือข่ายหรือ IP สำหรับนำไปอ้างอิงในกฎ ทำให้จัดการรายการจำนวนมากได้สะดวก โครงงานใช้ชุด th_allow ซึ่งอ้างอิงช่วง IPv4 ของประเทศไทย 1,196 CIDR blocks และตั้งนโยบาย INPUT เป็น DROP หลังอนุญาตทราฟฟิกที่จำเป็น
หากใส่รายการจำนวนมากเป็นกฎแยกใน iptables
การตรวจสอบอาจต้องไล่พิจารณากฎตามลำดับซึ่งมีลักษณะเชิงเส้น O(N) ขณะที่ ipset

ใช้โครงสร้างข้อมูลสำหรับค้นหาสมาชิกแบบแฮชในชุดข้อมูลที่เหมาะสม จึงช่วยลดภาระการตรวจสอบรายการ IP จำนวนมากได้ โดยความซับซ้อนจริงขึ้นกับชนิดชุดข้อมูลและการตั้งค่าที่ใช้

การกรองตามประเทศช่วยลดพื้นที่การถูกโจมตี (Attack Surface Reduction) จากแหล่งที่ไม่จำเป็น แต่ไม่ใช่การยืนยันตัวตนและไม่สามารถรับประกันว่าจะหยุดผู้โจมตีทั้งหมดได้ เพราะฐานข้อมูลช่วง IP อาจเปลี่ยน ผู้ใช้ที่เดินทางหรือใช้ VPN/Proxy ซึ่งมีทางออกในประเทศไทยอาจยังเข้าถึงได้ และผู้ใช้ที่ชอบธรรมอาจถูกปฏิเสธ จึงต้องใช้ร่วมกับมาตรการชั้นอื่นตามแนวคิด Defense-in-Depth

2.5 เว็บเซิร์ฟเวอร์และ Reverse Proxy

Nginx รับคำขอ HTTP/HTTPS จากผู้ใช้และส่งต่อไปยังบริการภายในได้ เรียกบทบาทนี้ว่า Reverse Proxy โครงงานแยก Nginx ด้านหน้า (Frontend/Edge) ออกจาก Backend ที่ฟังเฉพาะ 127.0.0.1:8080 เพื่อไม่ให้ Backend เปิดรับการเชื่อมต่อโดยตรงจากเครือข่ายภายนอก สถาปัตยกรรมสองชั้นนี้ช่วยให้ Frontend รับผิดชอบการยุติ TLS (TLS Termination) การจำกัดอัตราคำขอ การปฏิเสธ path ที่ไม่ต้องการ และการทำ Cache สำหรับคำขอที่เหมาะสม จึงช่วยลดคำขอที่ต้องส่งต่อไปยัง Backend, PHP-FPM และฐานข้อมูล ทั้งนี้ Cache ต้องตั้งค่าอย่างระมัดระวังเพื่อไม่ให้ข้อมูลเฉพาะบุคคลหรือข้อมูลที่ต้องอาศัยสถานะผู้ใช้ถูกเก็บหรือส่งซ้ำผิดคน

2.6 การตรวจจับการโจมตีและ AI SecOps

Access log เก็บรายละเอียดคำขอ เช่น IP, path, method, เวลา และรหัสสถานะ HTTP สคริปต์ analyze-logs.py อ่าน log แล้วจัดหมวดหมู่พฤติกรรมที่เข้าข่าย เช่น XML-RPC, การเดารหัสผ่าน, การสแกนช่องโหว่ และการสุ่มค้นหาชื่อผู้ใช้ จากนั้น secdash-ai.py นำข้อมูลสรุปไปให้ AI วิเคราะห์และเสนอแนวทางรับมือ โดยปิดบังเลขท้าย IP ก่อนส่งข้อมูล และออกแบบให้ AI ทำหน้าที่เป็นที่ปรึกษาแบบอ่านอย่างเดียว

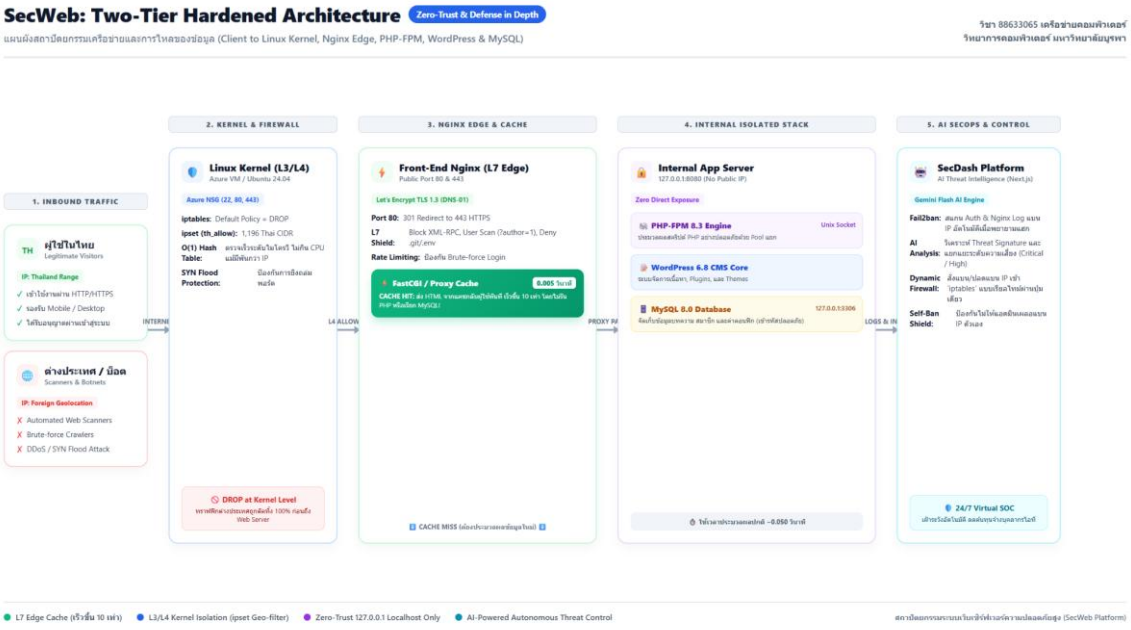
ผลจากการจัดหมวดหมู่ log เป็นการประมาณจากกฎที่เขียนไว้ ไม่ใช่หลักฐานยืนยันว่าทุกคำขอเป็นการโจมตีจริง หรือยืนยันว่าผู้โจมตีเข้าถึงระบบสำเร็จ

บทที่ 3 วิธีดำเนินงาน

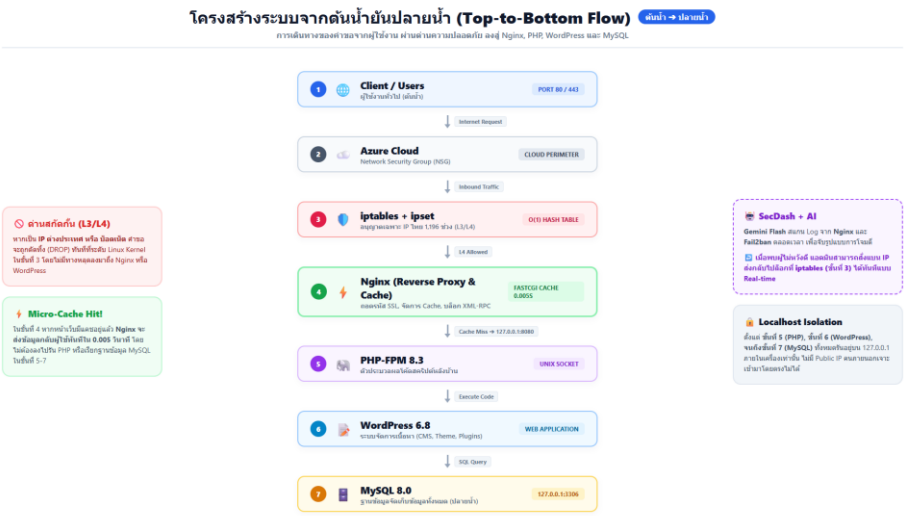
3.1 ภาพรวมสถาปัตยกรรม

เส้นทางหลักของคำขอคือ ผู้ใช้ ⟶ DNS ของ DuckDNS (พอร์ต 53) ⟶ Public IP ของ Azure VM ⟶ กฎเครือข่าย Linux ด้วย iptables/ipset (ชั้น L3/L4) ⟶ Nginx Frontend/Reverse Proxy บน HTTPS พอร์ต 443 (ชั้น L7) ⟶ Nginx Backend ที่ 127.0.0.1:8080 ⟶ PHP-FPM ผ่าน FastCGI ⟶ WordPress ⟶ MySQL ที่เชื่อมต่อเฉพาะภายในเครื่องบนพอร์ต 3306 ขณะเดียวกัน access log จะถูกประมวลผลเป็นรายงาน JSON และแสดงผลบน SecDash

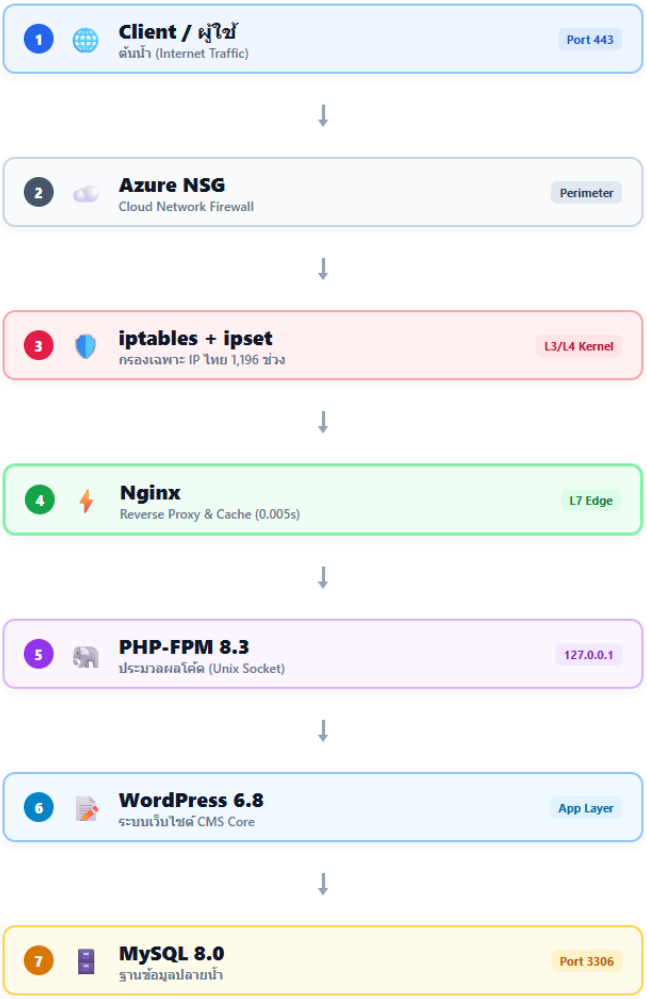
ภาพที่ 3.1 สถาปัตยกรรมระบบ SecWeb: การป้องกันหลายชั้นและการไหลของข้อมูล



ภาพที่ 3.2 ลำดับการไหลของคำขอจากผู้ใช้ไปยังฐานข้อมูล



ภาพที่ 3.3 แผนผังขั้นตอนการประมวลผลตั้งแต่ต้นทางถึงปลายทาง



ชั้นระบบ	องค์ประกอบ	หน้าที่
ภายนอก	ผู้ใช้ / DuckDNS (DNS: UDP/TCP 53; HTTPS: TCP 443)	เรียกเว็บไซต์ผ่านชื่อโดเมน
เครือข่าย	Azure NSG / iptables / ipset (Linux L3/L4)	คัดกรองการเชื่อมต่อและจำกัด IP ต้นทาง
เว็บด้านหน้า	Nginx Frontend / TLS 1.2–1.3 / Rate Limit / Cache (L7)	รับ HTTPS กรองคำขอ และส่งต่อ
แอปพลิเคชัน	Nginx Backend 127.0.0.1:8080 / PHP-FPM / WordPress	ประมวลผลหน้าเว็บ
ข้อมูล	MySQL 127.0.0.1:3306 (ภายในเครื่อง)	เก็บข้อมูล WordPress โดยไม่เปิดฐานข้อมูลสู่ภายนอก
เฝ้าระวัง	Access log / Python / AI / SecDash	สรุปสถิติและแสดงเหตุการณ์ความปลอดภัย

3.2 การเตรียมเครื่องเซิร์ฟเวอร์

1. สมัคร Azure for Students และสร้าง VM ชื่อ nw-server ในภูมิภาค Indonesia Central ด้วย Ubuntu Server 24.04 LTS
2. ตั้งค่าการเข้าถึงด้วย SSH public key และใช้บัญชี deploy แทนการเข้าเป็น root โดยตรง
3. เชื่อมชื่อโดเมน nenenainaemak.duckdns.org กับ Public IP ของ VM
4. ติดตั้ง Nginx, MySQL, PHP-FPM และส่วนขยาย PHP ที่ WordPress ต้องใช้
5. สร้างฐานข้อมูล wordpress และผู้ใช้ wpuser พร้อมกำหนดสิทธิ์เฉพาะฐานข้อมูลที่จำเป็น
6. ดาวน์โหลด WordPress และตั้งค่า Nginx เบื้องต้นเพื่อให้ทำขั้นตอนติดตั้งผ่านเบราว์เซอร์

3.3 การติดตั้งเว็บและ HTTPS

หลังติดตั้ง WordPress แล้ว ได้ขอใบรับรอง Let’s Encrypt ผ่าน DNS-01 Challenge และตั้งค่า Nginx ให้เปลี่ยนเส้นทางจาก HTTP ไป HTTPS พร้อมใช้ TLS 1.2 และ TLS 1.3 และเพิ่ม Strict-Transport-Security (HSTS) เหตุผลที่เลือก DNS-01 คือการยืนยันสิทธิ์ผ่านระเบียน TXT ใน DNS โดยไม่ต้องให้เซิร์ฟเวอร์ตรวจสอบของ Let’s Encrypt เชื่อมต่อเข้าพอร์ต 80 ของ VM โดยตรง
ซึ่งเหมาะกับสภาพแวดล้อมที่มีการจำกัดการเชื่อมต่อขาเข้าด้วย GeoIP Firewall ทั้งนี้
ควรตรวจสอบการต่ออายุใบรับรองและสิทธิ์ของ DNS API token อย่างสม่ำเสมอ

3.4 การตั้งค่าความปลอดภัยเครือข่าย

7. ตั้งค่า SSH ให้ปิดการล็อกอิน root และการยืนยันตัวตนด้วยรหัสผ่าน อนุญาตเฉพาะ public key และผู้ใช้ deploy
8. ดาวน์โหลดช่วง IP ประเทศไทยมาเก็บใน ipset ชื่อ th_allow และใช้ iptables อนุญาตพอร์ต 22, 80 และ 443 เฉพาะต้นทางที่อยู่ในชุดดังกล่าว โดยต้องตรวจสอบให้แน่ใจว่า Azure Network Security Group (NSG) และกฎภายในเครื่องสอดคล้องกัน และมีช่องทางกู้คืนหากผู้ดูแลถูกบล็อกโดยไม่ตั้งใจ
9. ตั้ง cron ให้อัปเดตรายการ IP ไทยเป็นรายสัปดาห์ โดยตรวจสอบข้อมูลก่อนสลับชุดรายการ
10. กำหนด Nginx ให้ปฏิเสธ /xmlrpc.php และคำขอที่มีพารามิเตอร์ author= รวมถึงจำกัดความถี่การเรียก wp-login.php
11. ติดตั้ง fail2ban สำหรับตรวจจับการล็อกอิน SSH และ WordPress ที่ล้มเหลวซ้ำ แล้วแบน IP ตามช่วงเวลาที่กำหนด
12. แยก Nginx frontend และ backend โดย backend ฟังเฉพาะ 127.0.0.1:8080 และกำหนด cache สำหรับคำขอที่เหมาะสม

3.5 การติดตั้ง Dashboard และ AI

สคริปต์ analyze-logs.py ประมวลผล access log และสร้าง report.json ทุกชั่วโมง จากนั้น secdash-ai.py อ่านข้อมูลสรุป ปิดบังเลขท้าย IP ประเมินความผิดปกติ และเรียกใช้ AI เพื่อจัดทำข้อสรุปลง ai_report.json หน้า SecDash สร้างด้วย Vue 3, TypeScript, Vite และ Tailwind CSS และป้องกันด้วย HTTP Basic Authentication ระบบ SecDash Control API (FastAPI) ใช้สำหรับควบคุม iptables และ fail2ban
โดยควรกำหนดการตรวจสอบสิทธิ์ บันทึก Audit Logs และกลไก Admin Self-Ban Protection
เพื่อป้องกันผู้ดูแลบล็อก IP ของตนเอง

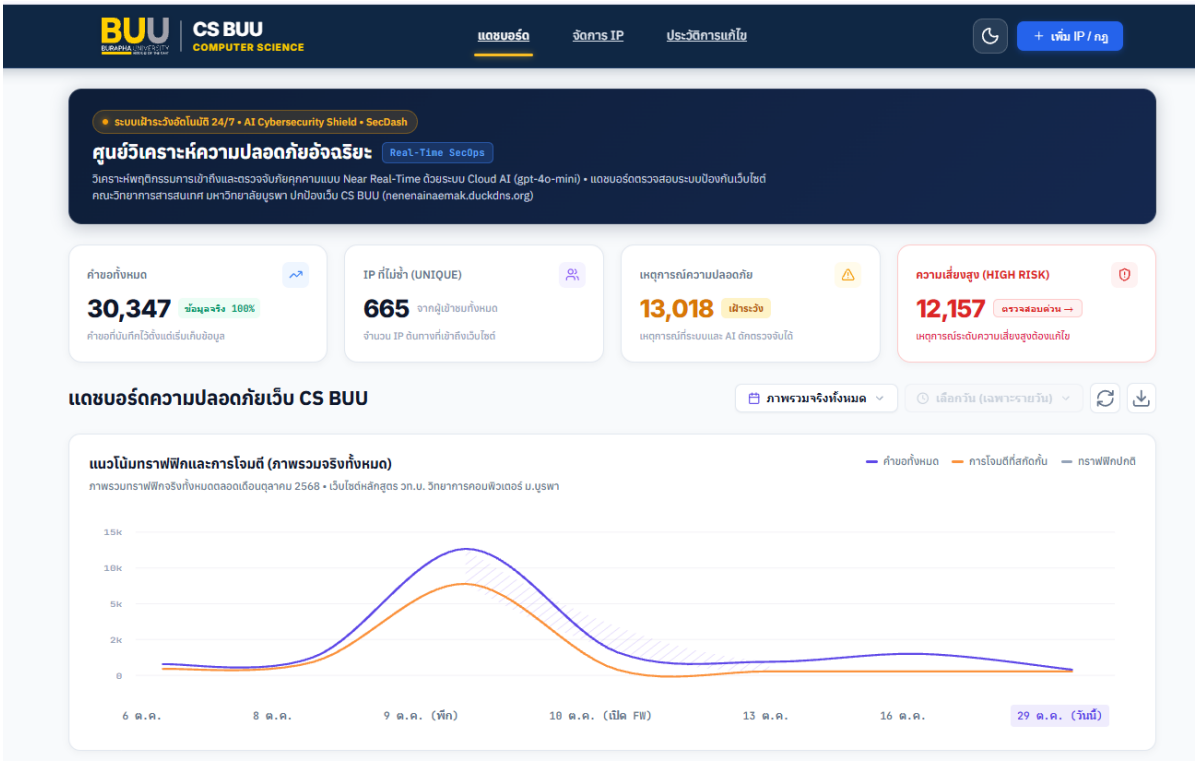
ก่อนเผยแพร่รายงานหรือภาพหน้าจอ ต้องปิดบังรหัสผ่าน token, API key และข้อมูลรับรองทั้งหมด รวมถึงปิดบัง IP เต็มของผู้ใช้ทั่วไปเมื่อไม่จำเป็นต่อการอธิบายผล

สำหรับหน้าจอผู้ดูแลและ Audit Logs อาจจำเป็นต้องใช้ IP เต็มเพื่อค้นหาเหตุการณ์และจัดการกฎไฟร์วอลล์ แต่เมื่อจัดทำรายงานเพื่อเผยแพร่ควรปิดบัง IP ของผู้ใช้ที่ไม่เกี่ยวข้องหรือขออนุญาตก่อน โดยฉบับนี้ปิดบัง IP ของผู้ใช้ที่ถูกปลดแบนในภาพที่ ก.2 แล้ว

บทที่ 4 ผลการดำเนินงานและการทดสอบ

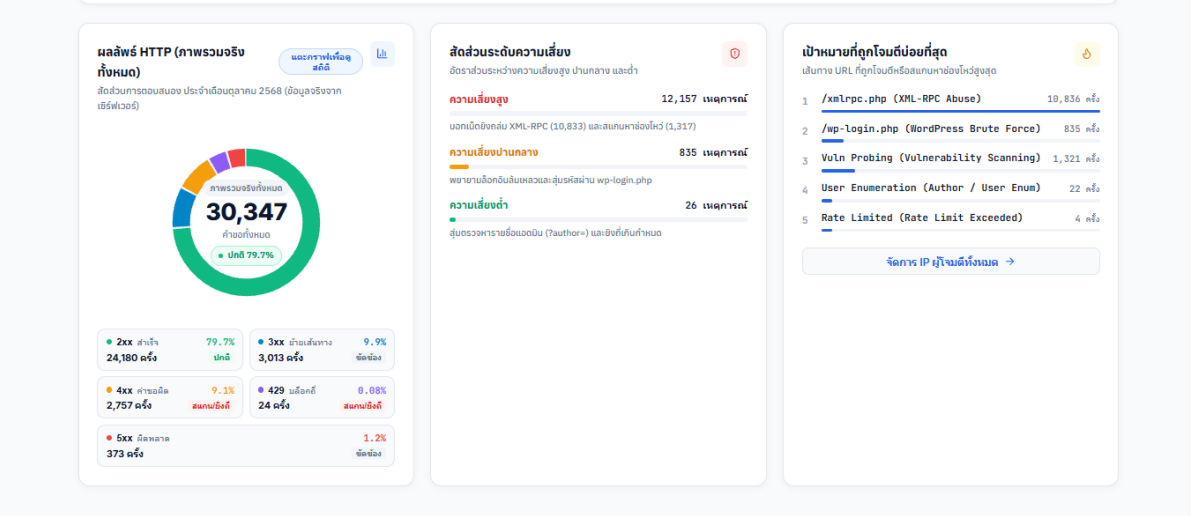
4.1 ผลการทำงานของระบบ

จากเอกสารขั้นตอนและภาพหน้าจอที่แนบ ระบบมีแดชบอร์ดแสดงจำนวนคำขอ HTTP จำนวน IP ที่ไม่ซ้ำ เหตุการณ์ที่จัดเป็นความเสี่ยงสูง กราฟแนวโน้มทราฟฟิก สัดส่วนรหัสสถานะ HTTP รายการเป้าหมายที่ถูกเรียกบ่อย ผลวิเคราะห์จาก AI หน้าจัดการ IP และประวัติการเปลี่ยนแปลง IP

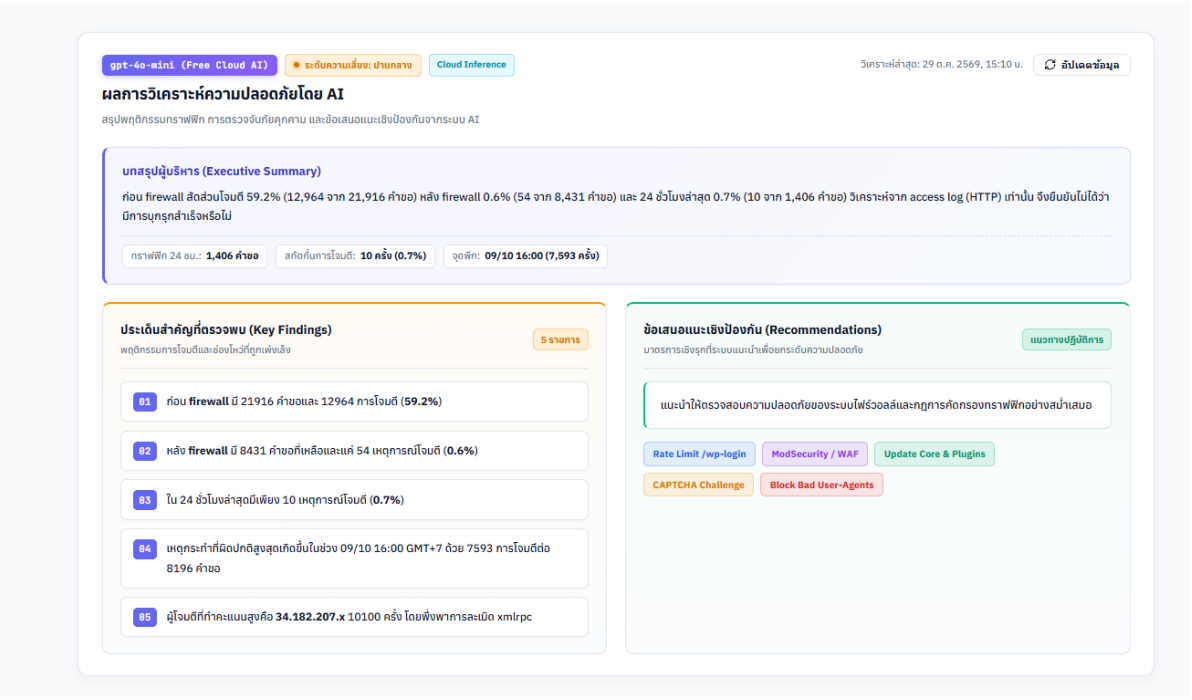


ภาพที่ 4.1 หน้าจอแสดงผลรวมสถิติทราฟฟิก กราฟแนวโน้ม และสถานะการป้องกันของ SecDash

หมายเหตุ: ป้ายวันที่ในภาพหน้าจอเดิมยังต้องยืนยันกับบันทึกบนเซิร์ฟเวอร์
เนื่องจากไม่ตรงกับไทม์ไลน์ในข้อความหัวข้อ 4.2



ภาพที่ 4.2 ผลการวิเคราะห์แนวโน้มภัยคุกคามและสรุปสถานการณ์โดย AI (Executive Summary & Key Findings)



ภาพที่ 4.3 ข้อเสนอแนะเชิงป้องกัน (Recommendations) และสถิติคำขอย้อนหลัง 24 ชั่วโมง

4.2 ผลสถิติจาก Access Log

ตามข้อมูลสถิติในเอกสารโครงการ ณ วันที่ 28 ตุลาคม 2569 มีคำขอ HTTP รวม 29,701 ครั้ง และระบบจัดหมวดหมู่เหตุการณ์ที่เข้าข่ายการโจมตีได้ 13,010 ครั้ง จาก IP ที่ไม่ซ้ำ 660 หมายเลข ตัวเลขนี้เป็นผลจากกฎจำแนกในสคริปต์และควรตีความว่าเป็นเหตุการณ์ที่เข้าเงื่อนไขการตรวจจับ ไม่ใช่จำนวนการบุกรุกที่ยืนยันแล้ว

หมายเหตุการตรวจสอบไทม์ไลน์: ป้ายบนกราฟในภาพที่ 4.1 แสดง “10 ต.ค. (เปิด FW)” และข้อความ “ตุลาคม 2568” ขณะที่เอกสารขั้นตอนระบุวันเริ่มเปิด GeoIP Firewall และกฎ Nginx เป็น 24 ตุลาคม 2569 จึงยังมีข้อมูลขัดแย้งกัน ฉบับนี้ยังไม่แก้ข้อความในภาพหน้าจอเพื่อไม่ดัดแปลงหลักฐาน ต้องตรวจสอบ system log, history คำสั่ง หรือบันทึกการเปลี่ยนกฎบนเซิร์ฟเวอร์ก่อน แล้วจึงแก้ข้อความ 4.2 หรือบันทึกภาพใหม่ให้ตรงกับวันที่ยืนยันได้

ช่วงเวลา	จำนวนคำขอ	เหตุการณ์ที่จัดเป็นการโจมตี	สัดส่วนตามรายงาน
ก่อนเปิด Firewall	21,916	12,964	59.2%
หลังเปิด Firewall	7,785	46	0.6%
รวมตามรายงาน	29,701	13,010	43.8%

หมายเหตุ: ตารางที่ 4.2 เป็นสถิติตัดรอบ ณ วันที่ 28 ตุลาคม 2569 จำนวน 29,701 คำขอ ส่วนภาพหน้าจอแดชบอร์ดในภาพที่ 4.1–4.3 บันทึกข้อมูลสะสม ณ วันที่ 29 ตุลาคม 2569 จำนวน 30,347 คำขอ ซึ่งมากกว่า 646 คำขอ และมีเหตุการณ์ที่จัดประเภทเพิ่มขึ้น 8 ครั้งตามข้อมูลที่ระบุในเอกสารโครงการ ตัวเลขเป็นคนละเวลาบันทึก ไม่ควรนำมาเทียบเสมือนเป็น snapshot เดียวกัน

เอกสารระบุว่าช่วงก่อนเปิด Firewall มีการเรียก /xmlrpc.php จาก IP ที่ปิดบังเป็น 34.182.207.x จำนวนประมาณ 10,100 ครั้ง และหน้าแดชบอร์ดแสดงเป้าหมาย XML-RPC จำนวนมาก
การเปรียบเทียบก่อนและหลังแสดงความสัมพันธ์ระหว่างการเปิดมาตรการกรองกับสัดส่วนเหตุการณ์ที่ถูกจัดประเภท แต่ยังไม่สามารถสรุปว่า firewall เป็นสาเหตุเดียว หรือว่าการโจมตีถูกสกัดกั้นทั้งหมดได้
หากไม่มีการทดสอบควบคุมและหลักฐานเครือข่ายเพิ่มเติม

4.3 ผลการทดสอบ

กรณีทดสอบ	วิธีตรวจสอบ	ผลที่ระบุในเอกสารโครงการ	หลักฐานในภาคผนวก ข
HTTPS	เปิดเว็บและตรวจ header	หน้าเว็บใช้ใบรับรอง Let's Encrypt และมี HSTS	มีภาพ ข.1: แสดง HTTP headers และ HSTS; ไม่ใช่หลักฐานตรวจใบรับรองครบทุกด้าน
SSH hardening	ตรวจ sshd -T และทดสอบการล็อกอิน	อนุญาต key-based login และปฏิเสธ root/password login	มีภาพ ข.6: แสดงผล sshd -T ว่า PermitRootLogin no และ PasswordAuthentication no; พร้อม iptables INPUT policy DROP และกฎ ACCEPT สำหรับ loopback/RELATED,ESTABLISHED/พอร์ต 22,80,443
GeoIP firewall	ตรวจ ipset/iptables และทดสอบจากเครือข่าย	อนุญาตการเข้าถึงจากไทยและรายงานว่าโหนดต่างประเทศ timeout	มีภาพ ข.8: แสดงการทดสอบจาก foreign-scanner ที่หมดเวลาเชื่อมต่อพอร์ต 443; ภาพ ข.6 แสดงกฎ iptables และ match-set th_allow สำหรับพอร์ต 22,80,443

กรณีทดสอบ	วิธีตรวจสอบ	ผลที่ระบุในเอกสารโครงการ	หลักฐานในภาคผนวก ข
Nginx security rules	เรียก /xmlrpc.php และ ?author=1	ตอบกลับ HTTP 403	มีภาพ ข.2: แสดง /xmlrpc.php ตอบ HTTP 403; ยังไม่มีภาพทดสอบ ?author=1 แยกต่างหาก
Rate limit / cache	เรียก wp-login ซ้ำและตรวจ X-Cache-Status	มีการจำกัดคำขอและมีผล HIT หลังการเรียกซ้ำ	มีภาพ ข.5: แสดง X-Cache-Status: HIT; ยังไม่มีภาพแยกที่แสดงผลทดสอบ Rate Limit
fail2ban	ตรวจ regex และแบน IP สำหรับทดสอบ	เอกสารระบุว่าจับได้ 119 บรรทัดและทดสอบ ban/unban ได้	มีภาพ ข.3 และ ข.7: ภาพ ข.7 แสดง Total failed = 119 และ Total banned = 14 สำหรับ jail wp-login; ค่า Currently banned = 0 เป็นสถานะขณะบันทึกภาพ ไม่ได้แปลว่าไม่เคยมีการแบน
SecDash authentication	เรียก URL โดยไม่ส่งข้อมูลรับรอง	ตอบกลับ HTTP 401 Unauthorized	มีภาพ ข.4: แสดง HTTP 401 Unauthorized และ WWW-Authenticate: Basic realm="Security Dashboard" เมื่อเรียก SecDash โดยไม่ส่งข้อมูลรับรอง
งานวิเคราะห์อัตโนมัติ	ตรวจเวลาไฟล์ JSON และ log	เอกสารระบุว่ารายงานอัปเดตตามรอบ Cron ทุกชั่วโมง	ไม่มีภาพเวลาไฟล์ JSON/log ที่ยืนยันรอบ Cron ในฉบับนี้
การบล็อก/ปลดแบน IP ผ่าน SecDash Control API	สั่งบล็อกและปลดแบนผ่านหน้าแดชบอร์ด จากนั้นตรวจ iptables -L INPUT -v -n, fail2ban-client status และ Audit Logs	ระบบมีฟังก์ชันสั่งบล็อกและปลดแบน IP ผ่านแดชบอร์ด โดยออกแบบให้ปรับปรุงกฎ iptables/fail2ban และบันทึกประวัติใน Audit Logs	มีภาพหน้าจอในภาคผนวก ก สำหรับ UI/Audit Log แต่ไม่มีภาพคำสั่งตรวจสอบครบทุกขั้นตอนในฉบับนี้

4.4 ข้อจำกัดในการแปลผล

สถิติขึ้นกับกฎจำแนกของ analyze-logs.py เช่น การเรียก xmlrpc.php จะถูกจัดเป็น xmlrpc_abuse ตาม path โดยไม่จำเป็นต้องทราบเจตนาของผู้เรียก และการนับจาก access log จะเห็นเฉพาะคำขอที่มาถึงชั้นเว็บเซิร์ฟเวอร์ ไม่ครอบคลุมแพ็กเก็ตที่ firewall ทิ้งก่อนถึง Nginx
ดังนั้นตัวเลขก่อนและหลังจึงอาจใช้ช่วงข้อมูลที่ไม่เท่ากันและไม่ใช่ตัวชี้วัดการบุกรุกโดยตรง

การแปลผลสถิติควรพิจารณาช่วงเวลาที่บันทึกข้อมูลและเวลาที่เปิดใช้มาตรการให้ตรงกัน
เนื่องจากจำนวนคำขอในแต่ละหน้าจออาจแตกต่างกันตามเวลาที่เก็บข้อมูล
และควรใช้ผลทดสอบจากระบบจริงประกอบการสรุปผล

บทที่ 5 สรุปผล ปัญหา และข้อเสนอแนะ

5.1 สรุปผล

โครงงานนี้ติดตั้งเว็บไซต์ WordPress บน VM ของ Microsoft Azure และเพิ่มมาตรการป้องกันหลายชั้น ตั้งแต่ SSH key, HTTPS, การกรอง IP ด้วย iptables/ipset, กฎความปลอดภัยของ Nginx, rate limiting, fail2ban ไปจนถึงระบบวิเคราะห์ access log และแดชบอร์ด SecDash มีการรวบรวมสถิติจาก log เพื่อใช้ตรวจสอบแนวโน้มทราฟฟิก แนวทาง Defense-in-Depth ช่วยแบ่งหน้าที่การป้องกันตั้งแต่ระดับเครือข่าย จนถึงเว็บแอปพลิเคชัน ทั้งนี้ สถิติจาก log เป็นเหตุการณ์ที่เข้าเงื่อนไขการจำแนก ไม่ใช่หลักฐานยืนยันการบุกรุก หรือยืนยันว่าระบบป้องกันภัยคุกคามได้ทั้งหมด ระบบยังมีฟังก์ชันควบคุมไฟร์วอลล์ผ่าน Web API พร้อมกลไก Admin Self-Ban Protection เพื่อเพิ่มความปลอดภัย

5.2 ปัญหาที่พบและแนวทางแก้ไข

ปัญหา	แนวทางแก้ไขตามเอกสาร
สมัคร Oracle Cloud ไม่ผ่าน	เปลี่ยนมาใช้ Azure for Students
สร้าง VM ในบางภูมิภาคไม่ได้	เลือก Indonesia Central ตามนโยบายของบัญชีนักศึกษา
เครื่อง VM ใช้เครดิตสูง	ลดขนาดจาก B4als_v2 เป็น B2als_v2
WordPress เชื่อมต่อฐานข้อมูลไม่ได้	ตรวจให้รหัสผ่านในฐานข้อมูลและ wp-config.php ตรงกัน
Nginx ไม่ยอมรับรูปแบบ http2 on;	ใช้ listen 443 ssl http2; ตามเวอร์ชันที่ติดตั้ง
ขอใบรับรอง DuckDNS ไม่ผ่าน	ตรวจ token ให้ไม่มีอักขระขึ้นบรรทัดใหม่ และเก็บเป็นความลับ
AI provider บางรายเชื่อมต่อไม่ได้จากภูมิภาคคลาวด์	ใช้ระบบ fallback ไปยังผู้ให้บริการสำรองหรือกฎแบบกำหนดแน่นอน
ผู้ดูแลอาจบล็อก IP ของตนเองจนขาดการเชื่อมต่อ	เตรียมช่องทางกู้คืนผ่าน Azure Portal Run Command หรือเครือข่ายสำรอง และทดสอบ Admin Self-Ban Protection ทั้งฝั่ง Frontend/API ก่อนใช้งานจริง

5.3 ข้อเสนอแนะ

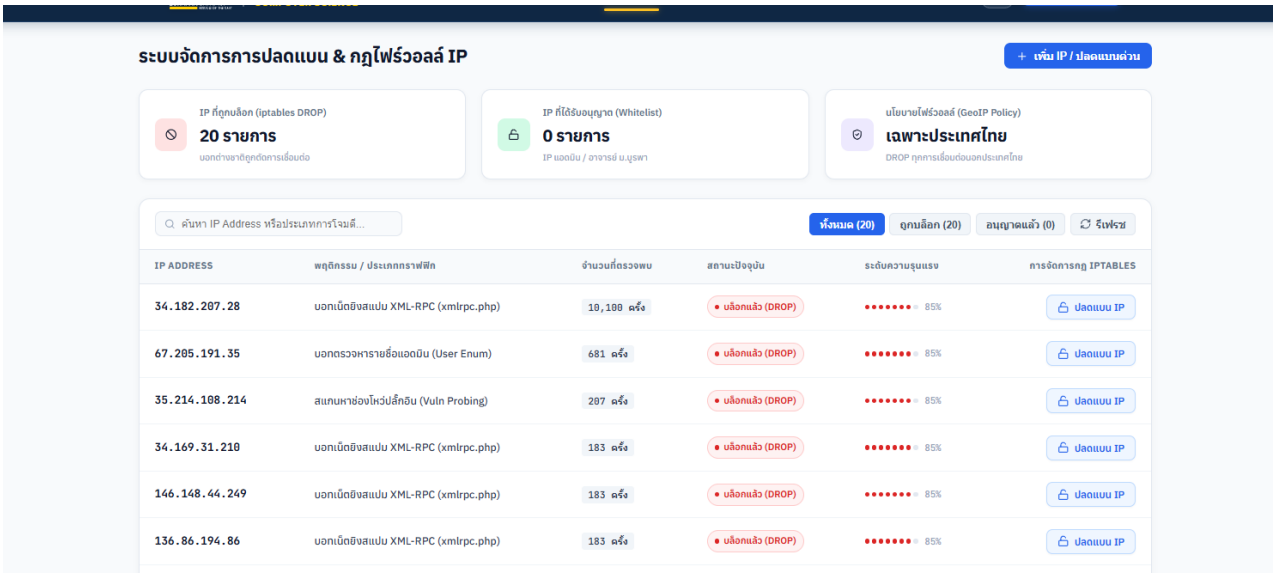
- ทบทวนกฎ firewall และรายการ IP ประเทศไทยเป็นระยะ พร้อมมีช่องทางกู้คืนเมื่อผู้ดูแลถูกบล็อกตัวเอง
- จำกัดพอร์ตที่เปิดใน Azure Network Security Group ให้สอดคล้องกับ firewall ภายในเครื่อง และจำกัด SSH ให้เข้าถึงได้เฉพาะแหล่งที่จำเป็นเมื่อทำได้
- ตรวจสอบการสำรองข้อมูลเป็นประจำ และทดลองกู้คืนทั้งฐานข้อมูล ไฟล์ WordPress และไฟล์ตั้งค่า
- ปรับปรุงการจำแนกเหตุการณ์โดยแยกคำขอที่น่าสงสัยออกจากเหตุการณ์ที่ยืนยันแล้ว พร้อมเก็บเวลาของการทดสอบให้ตรงกัน
- ใช้บัญชีผู้ดูแลเท่าที่จำเป็น อัปเดต WordPress และปลั๊กอิน และพิจารณาถอดปลั๊กอินที่ไม่จำเป็นหรือมีความเสี่ยง
- เก็บหลักฐานจากคำสั่งจริงและระบุวันที่ทดสอบทุกครั้ง ไม่ควรใช้คำว่า ‘ป้องกันได้ 100%’ หรือ ‘ปลอดภัยทั้งหมด’ จากข้อมูล log เพียงอย่างเดียว

บรรณานุกรม / เอกสารอ้างอิง

- เอกสารภายในโครงการ. (2569). ขั้นตอนการดำเนินงานทีละขั้นสำหรับรายงาน (report-steps.md). เอกสารประกอบการติดตั้งและทดสอบระบบ.
- เอกสารประกอบการเรียนเครือข่ายคอมพิวเตอร์. (2569). lecturenote1_2.txt. เนื้อหา IPv4, network address, broadcast address และ subnetting.
- Microsoft. Azure for Students. https://azure.microsoft.com/free/students/
- DuckDNS. Duck DNS. https://www.duckdns.org/
- Let's Encrypt. Challenge Types. https://letsencrypt.org/docs/challenge-types/
- Nginx. Beginner’s Guide. https://nginx.org/en/docs/beginners_guide.html
- Fail2ban. Documentation. https://www.fail2ban.org/
- WordPress.org. Hardening WordPress. https://wordpress.org/documentation/article/hardening-wordpress/

ภาคผนวก ก ภาพหน้าจอระบบ

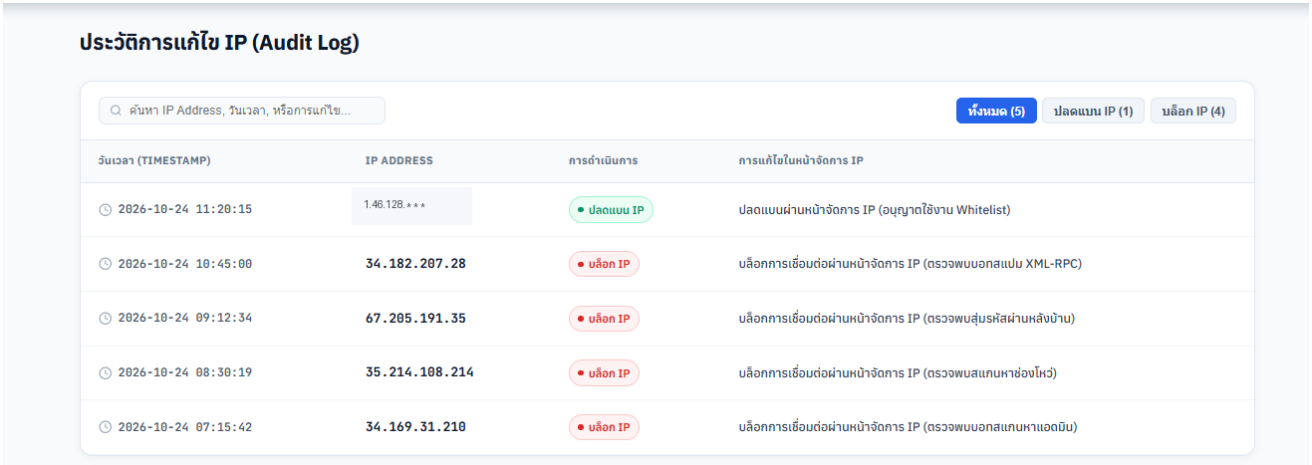
ภาพหน้าจอในภาคผนวก ก แสดงหน้าภาพรวมสถิติทราฟฟิก ผลการวิเคราะห์แนวโน้มภัยคุกคามจาก AI หน้าบริหารจัดการ IP และประวัติการแก้ไขกฎไฟร์วอลล์ (Audit Logs)



ภาพที่ ก.1 หน้าจอระบบจัดการการปลดแบนและกฎไฟร์วอลล์ IP (Unban & Threat Management)

หมายเหตุ: ภาพที่ ก.1 บันทึกสถานะเริ่มต้นก่อนเริ่มทดสอบ ซึ่ง Whitelist ยังเป็น 0 รายการ การปลดแบน IP ที่บันทึกใน Audit Log ดำเนินการในขั้นตอนทดสอบถัดมา ดังแสดงในภาพที่ ก.2

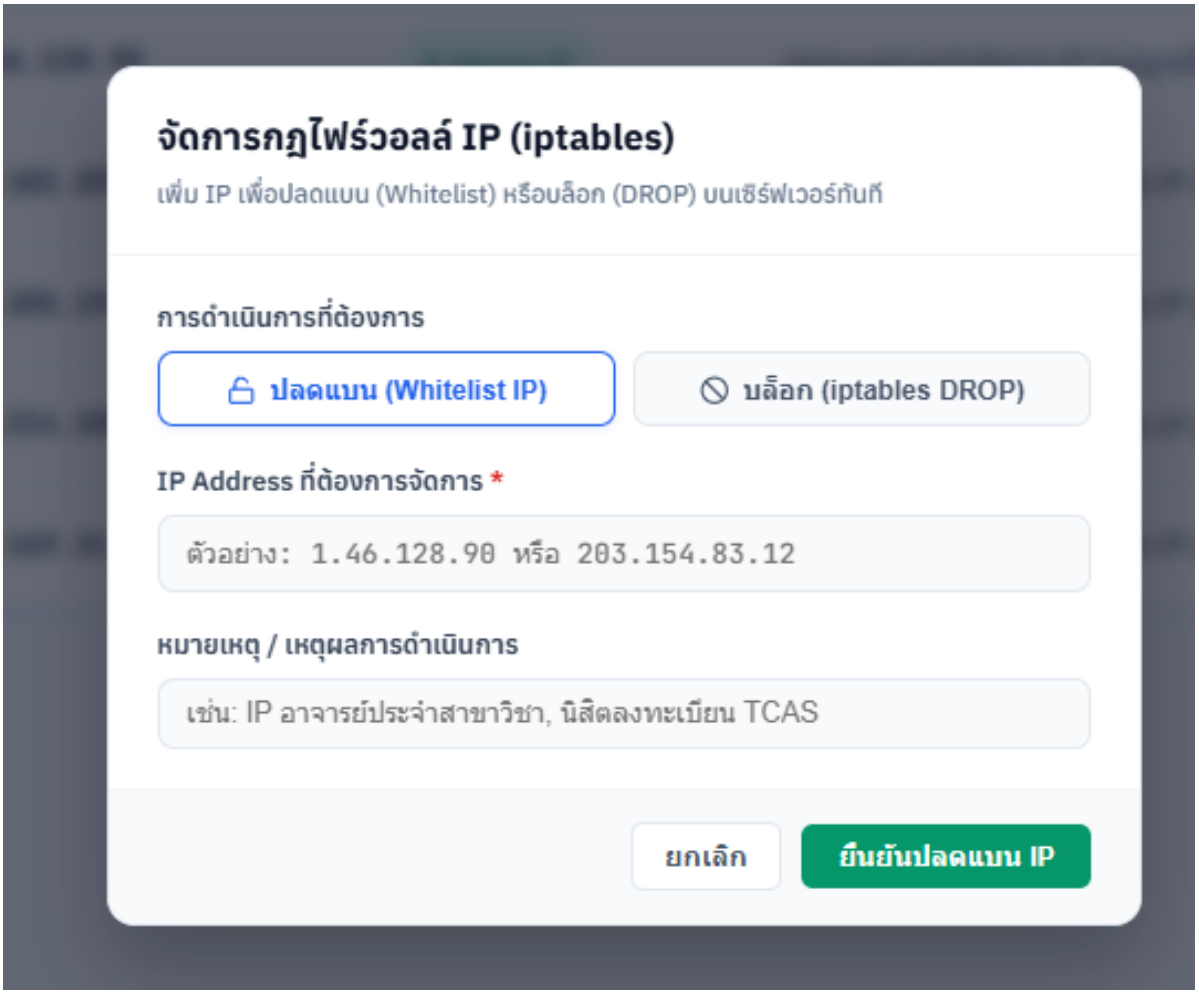
หมายเหตุ: ภาพที่ ก.1 แสดงจำนวน IP ที่ถูกบล็อก 20 รายการ ณ เวลาบันทึกภาพ ขณะที่ Audit Log ในภาพที่ ก.2 แสดงรายการที่บันทึกผ่านหน้าจอจัดการ 4 รายการ
จำนวนดังกล่าวอาจต่างกันเพราะหน้าจอหนึ่งแสดงสถานะรวม
ส่วนอีกหน้าจอแสดงเฉพาะกิจกรรมที่ถูกบันทึกไว้ใน Audit Log; ต้องตรวจสอบ log ของ fail2ban และระบบอัตโนมัติเพื่อยืนยันแหล่งที่มาของรายการที่เหลือ



ภาพที่ ก.2 หน้าจอบันทึกประวัติการแก้ไขกฎไฟร์วอลล์ (Audit Logs) แสดงรายการปลดแบนและบล็อก

หมายเหตุด้านความเป็นส่วนตัว: IP

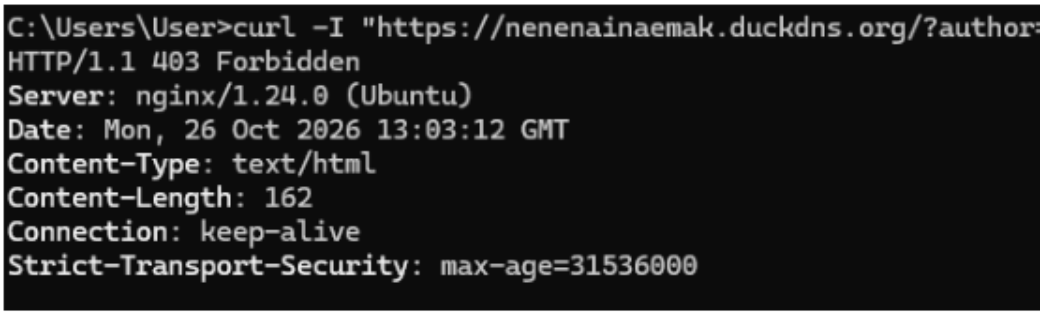
ของผู้ใช้ที่ถูกปลดแบนถูกปิดบังบางส่วนในภาพนี้เพื่อป้องกันการเปิดเผยข้อมูลผู้ใช้โดยไม่จำเป็น



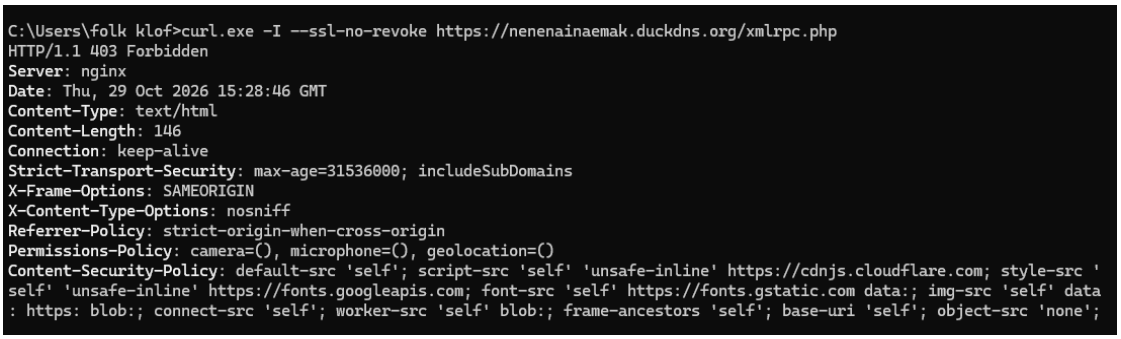
ภาพที่ ก.3 หน้าต่างโมดอลสำหรับเพิ่ม IP เข้า Whitelist หรือ DROP บนเซิร์ฟเวอร์

ภาคผนวก ข หลักฐานผลการทดสอบคำสั่งและการรักษาความปลอดภัย

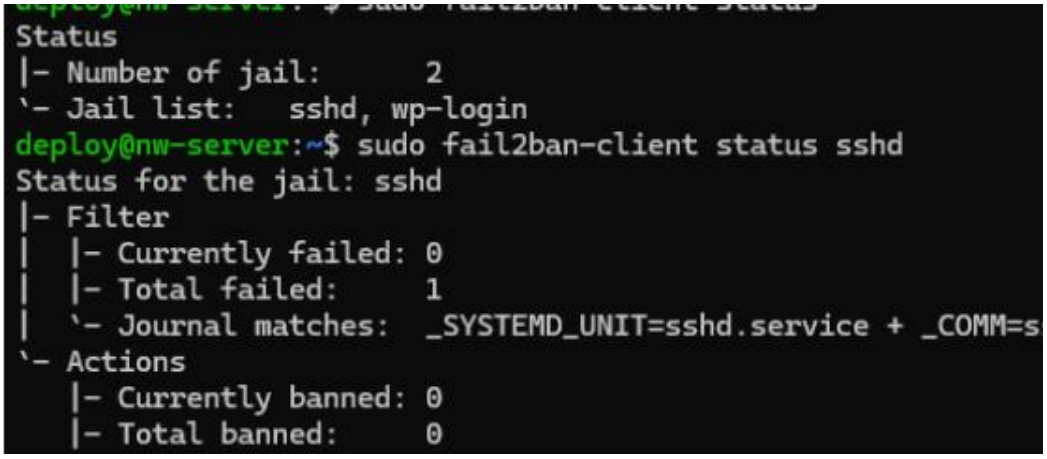
ภาพที่ ข.1 ผลการทดสอบ HTTP และส่วนหัวความปลอดภัย



ภาพที่ ข.2 ผลการทดสอบการเรียก /xmlrpc.php ซึ่งเซิร์ฟเวอร์ตอบกลับ HTTP 403 Forbidden



ภาพที่ ข.3 สถานะการทำงานของ Fail2ban



ภาพที่ ข.4 ผลการทดสอบ HTTP Basic Authentication ของ SecDash (HTTP 401 Unauthorized)

```
C:\Users\User> curl.exe -I --ssl-no-revoke https://nenenainaemak.duckdns.org/secdash/
HTTP/1.1 401 Unauthorized
Server: nginx
Date: Thu, 29 Oct 2026 16:53:35 GMT
Content-Type: text/html
WWW-Authenticate: Basic realm="Security Dashboard"
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
Content-Security-Policy: default-src 'self'; script-src 'self' ...
Cache-Control: no-store always
```

ภาพที่ ข.5 ผลการทดสอบ Micro-Cache ของ Nginx (X-Cache-Status: HIT)

```
C:\Users\User> curl.exe -I --ssl-no-revoke https://nenenainaemak.duckdns.org/
HTTP/1.1 200 OK
Server: nginx
Date: Thu, 29 Oct 2026 16:53:51 GMT
Content-Type: text/html; charset=UTF-8
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
X-Cache-Status: HIT
```

ภาพที่ ข.6 ผลตรวจ SSH Hardening และกฎ iptables + ipset

```
deploy@nw-server:~$ sudo sshd -T | grep -E 'permitrootlogin|passwordauthentication'
permitrootlogin no
passwordauthentication no

deploy@nw-server:~$ sudo iptables -L INPUT -n -v | head -n 9
Chain INPUT (policy DROP 70148 packets, 4407K bytes)
 pkts bytes target     prot opt in  out  source         destination
91838  322M ACCEPT     0    --  lo  *    0.0.0.0/0      0.0.0.0/0
4812K 1471M ACCEPT     0    --  *   *    0.0.0.0/0      0.0.0.0/0   ctstate RELATED,ESTABLISHED
 2023  106K ACCEPT     6    --  *   *    0.0.0.0/0      0.0.0.0/0   multiport dports 22,80,443 match-set th_allow src
```

ภาพที่ ข.7 สถานะ Fail2ban jail wp-login แสดง Total failed 119 และ Total banned 14



ภาพที่ ข.8 ผลทดสอบ GeoIP Drop จากเครือข่ายต่างประเทศ (Connection timeout)

